SECCIÓN 4.8

Exfiltración de datos y abuso de canales legítimos

Temas de esta sección:

- Qué es exfiltración y por qué no toda transferencia lo es
- La secuencia: acceso → recolección → compresión → transferencia
- Canales comunes: cloud, correo, repositorios, DNS
- Abuso de servicios legítimos: OneDrive, Google Drive, GitHub...
- Uso corporativo vs uso personal del destino

4.8 | Exfiltración no se confirma solo por volumen alto

Exfiltración ocurre cuando información de una organización se envía hacia un destino no autorizado. No toda transferencia de datos es exfiltración. El analista debe validar destino, proceso, datos accedidos antes y contexto del usuario.

La secuencia típica de exfiltración:

1 Acceso	2 Recolección	3 Compresión	4 Transferencia	5 Eliminación
Acceso a carpeta sensible	Descarga/copia de archivos	7z, zip, rar de los datos	Upload a destino externo	Borra archivos temporales

Error común: confirmar exfiltración solo por un volumen alto. Una subida de 5GB puede ser backup legítimo, sincronización o carga corporativa. También puede ser exfiltración. Validar siempre.

El analista SOC debe ser prudente, pero no ignorar señales de salida de datos.

4.8 | Canales de exfiltración y señales a revisar

Comparativo: uso legítimo vs uso sospechoso del mismo canal:

Canal	Contexto posiblemente legítimo	Contexto sospechoso
Cloud (OneDrive, Drive, Dropbox)	Dest: empresa-my.sharepoint.com (tenant corp) Horario laboral, usuario autorizado	Dest: drive.google.com (cuenta personal) Acceso previo a Contratos_Confidenciales + 4.8GB a la 1AM
Correo electrónico	Documentación enviada a cliente aprobado Sin adjuntos sensibles, hora laboral	Contratos_2026.zip → externalmail123@gmail.com Forwarding rule creada después de login extranjero
Repositorios de código	Desarrollador clona repo del proyecto asignado Desde dispositivo corporativo autorizado	marketing.luna clona payments-api-prod Desde dispositivo personal a las 22:15
DNS tunneling	Consultas DNS normales a servicios conocidos	12,000 queries/30min con subdominios largos aleatorios Proceso desconocido, cookies accedidas antes
Herramientas legítimas (rclone, curl)	backup.admin con rclone hacia corp-backups con ticket	ventas.mora con rclone, archivos comprimidos, sin ticket